Clase 4 · Esquema de seguridad y Perfiles de Protección

Seguridad Informática Básica · Dra. Cintia Quezada Reyes · martes 8 sep 2026 · Tema 1 (1.3) · Apuntes y resumen de estudio

PARTE 1 · Apuntes completos

1. El esquema de seguridad

Orden de construcción (como lo trazó en el pizarrón): **Entorno → Hipótesis → Amenazas / Riesgos / Vulnerabilidades → Políticas → Objetivos → Requerimientos → Implementación.**

Componente	Qué es
Entorno	Todo lo que rodea al activo: hardware, software, usuarios, instalaciones, clima, agua, sismos, polvo
Hipótesis	Cómo debería operar idealmente ("el cañón funcionará siempre") y el mantenimiento que la respalda (filtros, focos)
Amenazas, riesgos, vulnerabilidades	Lo que atenta contra el bien; **no se eliminan al 100 %, se mitigan**
Políticas	Reglas de la organización; en México suelen ser obsoletas o nadie las hace cumplir
Objetivos	Qué se quiere lograr (de hipótesis + amenazas + políticas)
Requerimientos	Qué debe cubrir el objeto o su entorno; catálogo de **CC / ISO 15408**: funcionales, de garantía, del objeto y del entorno
Implementación	Instalar y configurar, **por partes** y con apoyo de la dirección

> **Objetivos (examen)**
> Redactados como **acciones con verbo en infinitivo**, específicos y de **máximo 2 renglones**. Nada de 50 renglones con verbos amontonados.

2. Perfiles de Protección: las 11 partes

1. **Introducción:** resumen ejecutivo para el dueño, problema y cómo lo resuelve el esquema; lenguaje claro, sin jerga.
2. **Descripción del TOE** (Target of Evaluation): **no** comprometer herramientas o marcas concretas (si fallan, la responsabilidad legal y financiera cae en el consultor).
3. **Entorno de seguridad.**
4. **Hipótesis.**
5. **Amenazas:** agente + ataque + bien.
6. **Políticas de la organización** y normas que debe cumplir el TOE.

7. **Objetivos.**
8. **Requerimientos** (ISO/IEC 15408: funcionales y de garantía; perspectivas de usuario, desarrollador y evaluador).
9. **Justificación:** evidencia de que el PP es una defensa completa.
10. **Arquitectura:** mecanismos y herramientas seleccionados.
11. **Implementación:** instalar según manuales y configurar según las políticas.

En el audio la profesora profundizó en las primeras fases; Justificación y Arquitectura no se definieron individualmente.

3. Amenazas: agente + ataque + bien

- **Bien:** lo que se protege (ejemplo recurrente: el cañón del salón).
- Ejemplo: ladrón (agente) rompe el candado (ataque) para llevarse la caja (bien).
- Todos los humanos somos agentes potenciales. La clasificación formal de agentes y ataques queda pendiente.

Error común: evaluar amenazas sin el entorno completo.

4. Los 6 servicios de seguridad

Confidencialidad, integridad, disponibilidad (tríada CIA), **control de acceso, autenticación y no repudio.** Los estándares de seguridad consideran 6; el modelo OSI 7498 solo 5, porque da por sentada la disponibilidad.

Error común: confundir servicio (la necesidad) con mecanismo (la herramienta).

5. Casos y reglas de examen

- Examen de admisión UNAM: no se previó el entorno completo (dispositivos externos, complicidad).
- Exalumno que regaló su invento a una empresa por unas vacaciones: **si lo desarrollas con tus recursos, patentarlo a tu nombre antes de mostrarlo**.
- En ejercicios, redactar la necesidad práctica ("registrar accesos", "poner respaldos"), no solo "integridad".

> **Nomenclatura (resta medio punto)**
>
> Escribir siempre **ISO** o **ISO/IEC** antes del número (no "27000" a secas). Common Criteria: "Criterios Comunes", "CC", "CCITS" o "ISO/IEC 15408". Ortografía exacta: HIPAA, ITSEC, TCSEC, CTCPEC, ISO 17799, ISO 27001, ISO 27002.
>
> - Cuestionario de normatividad calificado en clase (SIB-EC05).

PARTE 2 · Resumen para estudiar

Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.

Concepto	Para recordar
Esquema	Entorno → hipótesis → amenazas → políticas → objetivos → requerimientos → implementación
Objetivos	Verbo en infinitivo, específicos, ≤ 2 renglones
TOE	No nombrar marcas ni herramientas
Amenaza	Agente + ataque + bien; se mitiga, no se elimina
Requerimientos	ISO/IEC 15408: funcionales y de garantía
Servicios	6 (OSI 7498 solo 5)

Las 11 partes del PP

Introducción, TOE, entorno, hipótesis, amenazas, políticas, objetivos, requerimientos, justificación, arquitectura, implementación.